Segurança em Redes de Computadores

Heron Aragão Monteiro

Protegendo Conexões TCP: TLS

- TLS
  - Transport Layer Security – Segurança na Camada Transporte
  - Padronizado pelo IETF
    - Internet Engineering Task Force, grupo internacional aberto que tem como missão o desenvolvimento de soluções e a promoção de padrões para Internet
  - Versão aprimorada do protocolo TCP que inclui serviços de segurança como
    - Sigilo e integridade de dados
    - Autenticação do ponto final
  - Foi o sucessor do protocolo SSL (Secure Sockets Layer)

Protegendo Conexões TCP: TLS

- TLS
  - É suportado por todos os navegadores e servidores Web populares
  - É basicamente usado por todos os sites populares
    - É identificado pelo navegador quando um URL começa com https
  - Entendendo a necessidade do TLS – cenário de comércio eletrônico
    - Bob está navegando na Web e acessa o site Alice Incorporated, que está vendendo perfume
    - O site Alice Incorporated exibe um formulário no qual Bob deve inserir
      - O tipo de perfume e quantidade desejados, seu endereço e o número de seu cartão de crédito
    - Bob insere as informações, clica em Enviar, e espera pelo recebimento (via correio postal comum) de seus perfumes
    - Bob também espera pelo recebimento de uma cobrança pelo seu pedido na próxima fatura do cartão de crédito

Protegendo Conexões TCP: TLS

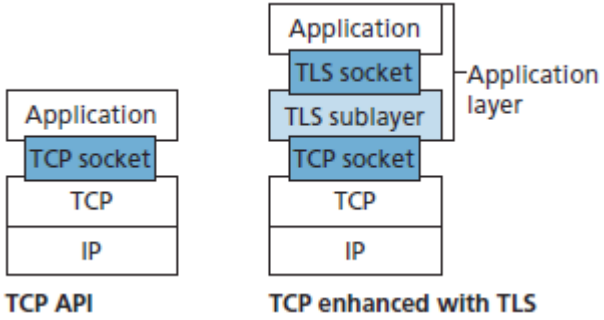
- TLS
  - Entendendo a necessidade do TLS – cenário de comércio eletrônico
    - Mas se nenhuma medida de segurança for tomada, Bob pode esperar por surpresas
      - Se nenhum sigilo for utilizado, um invasor pode interceptar o pedido de Bob e receber suas informações sobre o cartão
        - O invasor poderia, então, fazer compras à custa de Bob
      - Se nenhuma integridade de dados for utilizada, um invasor pode modificar o pedido de Bob
        - Fazendo Bob comprar dez vezes mais frascos de perfumes que o desejado
      - Se nenhuma autenticação do servidor for utilizada, um servidor pode exibir o famoso logotipo da Alice Incorporated, quando na verdade o site é mantido por Trudy, que está se passando por Alice Incorporated
        - Após receber o pedido de Bob, Trudy poderia ficar com o dinheiro dele e sumir
        - Ou Trudy poderia realizar um roubo de identidade obtendo o nome, endereço e número do cartão de crédito de Bob

Protegendo Conexões TCP: TLS

- TLS
  - É geralmente usado para oferecer segurança em transações que ocorrem pelo HTTP
  - Mas pode ser empregado por qualquer aplicação que execute o TCP
  - Provê uma Interface de Programação de Aplicação (API) com sockets, semelhante à API do TCP

Protegendo Conexões TCP: TLS

- TLS
  - Quando uma aplicação quer empregar o TLS, ela inclui classes/bibliotecas TLS
    - O TLS reside tecnicamente na camada de aplicação
    - Do ponto de vista do desenvolvedor é um protocolo de transporte que provê serviços do TCP aprimorados com serviços de segurança

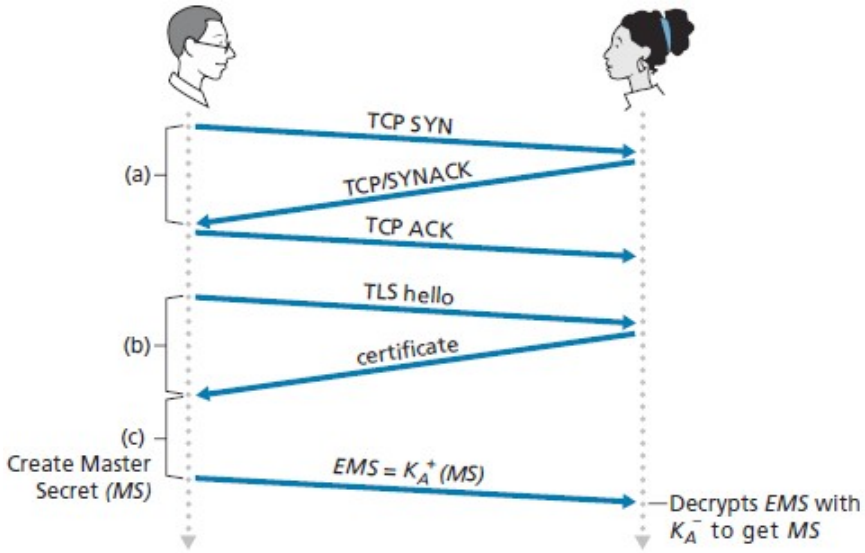


Protegendo Conexões TCP: TLS

- TLS – Uma visão abrangente (quase-TLS)
  - O cenário é definido para uma sessão de comunicação entre um cliente (Bob) e um servidor (Alice)
    - O servidor contém um par de chaves pública/privada e um certificado que associa sua identidade à sua chave pública
  - O quase-TLS possui três fases
    - Apresentação (handshake)
    - Derivação de chave
    - Transferência de dados

Protegendo Conexões TCP: TLS

- TLS – Uma visão abrangente (quase-TLS)
  - Apresentação (handshake)
    - Durante a fase de apresentação Bob precisa
      - Estabelecer uma conexão TCP com Alice (a)
      - Verificar se ela é realmente Alice (b)
        - O certificado foi assinado por uma Unidade Certificadora
      - Enviar-lhe uma chave secreta mestre
        - Utilizada para criar todas as chaves simétricas de que eles precisam para a sessão TLS (c)



Protegendo Conexões TCP: TLS

- TLS – Uma visão abrangente (quase-TLS)
  - Derivação de chave
    - O MS, agora compartilhado por Bob e Alice, poderia ser usado como a chave de sessão simétrica para toda a verificação de criptografia e integridade dos dados
    - Porém é mais seguro usarem, individualmente, chaves criptográficas diferentes para criptografia e verificação da integridade
    - Alice e Bob usam o MS para criar quatro chaves
      - E_B = chave de criptografia de sessão para dados enviados de Bob para Alice
      - M_B = chave HMAC de sessão para dados enviados de Bob para Alice
      - E_A = chave de criptografia de sessão para dados enviados de Alice para Bob
      - M_A = chave HMAC de sessão para dados enviados de Alice para Bob

Protegendo Conexões TCP: TLS

- TLS – Uma visão abrangente (quase-TLS)
  - Derivação de chave
    - As chaves E_B e E_A serão usadas para cifrar os dados
    - As chaves M_B e M_A serão usadas para verificar a integridade dos dados

Protegendo Conexões TCP: TLS

- TLS – Uma visão abrangente (quase-TLS)
  - Transferência de dados
    - Alice e Bob compartilham as mesmas quatro chaves de sessão
    - Agora podem enviar dados protegidos um ao outro por meio da conexão TCP
    - Como o TCP é um protocolo de fluxo de bytes, uma abordagem natural do TLS seria
      - Cifrar dados da aplicação enquanto são enviados
      - Transmitir os dados cifrados para o TCP
    - Mas seria necessário esperar até o fim da sessão TCP para verificar a integridade de todos os dados de Bob que foram enviados por toda a sessão

Protegendo Conexões TCP: TLS

- TLS – Uma visão abrangente (quase-TLS)
  - Transferência de dados
    - O TSL opera da seguinte forma
      - Ele divide o fluxo de dados em registros, anexa um HMAC a cada registro para a verificação da integridade, e cifra o registro+HMAC
        - Para criar o HMAC, Bob insere os dados de registro junto com a chave M_B em uma função de hash
        - Para cifrar o pacote registro+HMAC, Bob usa sua chave de criptografia de sessão E_B
      - Esse pacote cifrado é então transmitido ao TCP

Protegendo Conexões TCP: TLS

- TLS – Uma visão abrangente (quase-TLS)
  - Transferência de dados
    - Essa abordagem ainda é sujeita a falhas
      - Supondo que Trudy possui a habilidade de inserir, excluir e substituir segmentos no fluxo dos segmentos TCP enviados entre Alice e Bob
      - Ela poderia capturar dois segmentos enviados por Bob, inverter sua ordem, ajustar os números de sequência TCP (que não estão cifrados) e enviar dois segmentos na ordem inversa para Alice

Protegendo Conexões TCP: TLS

- TLS – Uma visão abrangente (quase-TLS)
  - Transferência de dados
    - Essa abordagem ainda é sujeita a falhas
      - Quando Alice receber os pacotes
        - O TCP acredita que está tudo bem e passa os dois registros para a subcamada TLS
        - O TLS decodifica os dois registros
        - O TLSL usa o HMAC em cada registro para verificar a integridade dos dados
        - O TLS passa os fluxos de bytes decifrados para a camada de aplicação
          - Mas o fluxo de bytes completo não está na ordem correta por causa da inversão dos registros

Protegendo Conexões TCP: TLS

- TLS – Uma visão abrangente (quase-TLS)
  - Transferência de dados
    - Essa abordagem ainda é sujeita a falhas
      - Solução
        - Usar números de sequência, da seguinte maneira:
          - Bob mantém um contador de números de sequência, que se inicia no zero e vai aumentando para cada registro TLS que ele envia
          - Esse número não é incluído no próprio registro, mas no cálculo do HMAC
            - O HMAC é agora um hash dos dados mais uma chave HMAC M_B mais o número de sequência atual
          - Alice rastreia os números de sequência de Bob, permitindo que ela verifique a integridade dos dados de um registro incluindo o número de sequência apropriado no cálculo do MAC

Protegendo Conexões TCP: TLS

- TLS – Uma visão abrangente (quase-TLS)
  - Transferência de dados
    - Essa abordagem ainda é sujeita a falhas
      - Solução
        - Dessa forma os números de sequência TCP podem ser alterados sem afetar o ordem real dos segmentos, que serão remontados na camada de aplicação
        - Essa solução previne o ataque de repetição, inversão ou remoção de de segmento
          - Mas ainda resta outra vulnerabilidade a ser discutida um pouco mais adiante – na versão TLS mais completa

Protegendo Conexões TCP: TLS

- TLS – Uma visão abrangente (quase-TLS)
  - Registro TLS
    - Ele consiste dos seguintes campos
      - Tipo
        - Indica se o registro é uma mensagem de apresentação (handshake) ou uma mensagem que contém dados da aplicação
        - Também usado para encerrar a conexão TLS
      - Versão
      - Comprimento
        - Usado para extrair os registros TLS do fluxo de bytes TCP da entrada
      - Dados
      - MAC

Protegendo Conexões TCP: TLS

- TLS – Uma visão mais completa
  - Aqui é examinada a essência do protocolo TLS atual
  - Apresentação (handshake) TLS
    - O TLS permite que Alice e Bob concordem, no início da sessão TLS, sobre o algoritmo criptográfico que irão utilizar
    - Nessa fase Alice e Bob enviam nounces que serão usados para a criação das chaves de sessão (E_B, M_B, E_A e M_A)

Protegendo Conexões TCP: TLS

- TLS – Uma visão mais completa
  - Apresentação (handshake) TLS
    - Passos para a apresentação real

      1. O cliente manda uma lista dos algoritmos criptográficos que ele utiliza e também um número aleatório (nounce)
      2. O servidor escolhe os algoritmos da lista
         - Um algoritmo de chave simétrica
         - Um algoritmo de chave pública
         - Um algoritmo HMAC com sua chave de sessão

         Ele envia ao cliente suas escolhas, seu certificado e seu nonce
      3. O cliente verifica o certificado, extrai a chave pública do servidor, gera um PMS(Pre-Master Secret), crifra o PMS com a chave pública do servidor e transmite o PMS cifrado para o servidor

Protegendo Conexões TCP: TLS

- TLS – Uma visão mais completa
  - Apresentação (handshake) TLS
    - Passos para a apresentação real

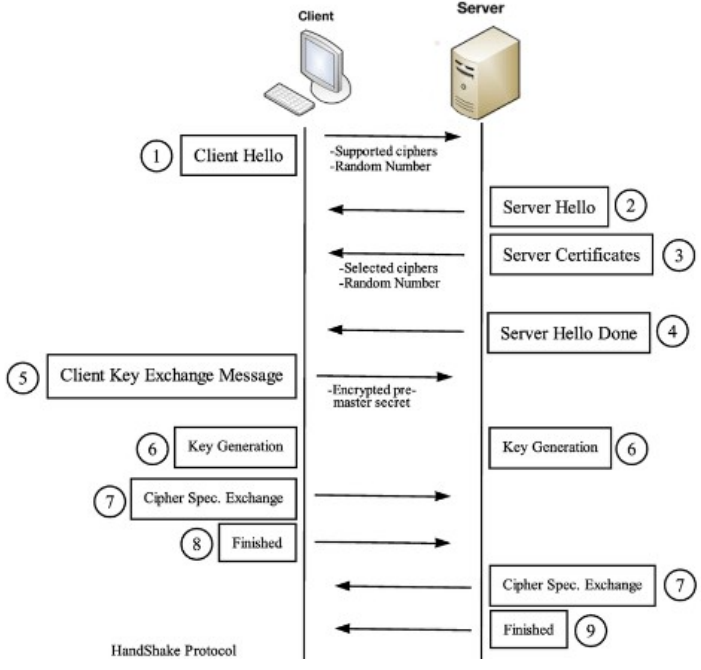
      4. Usando uma função de derivação comum, cliente e servidor calculam MS (Master Secret) a partir do PMS e dos nounces
         - Gerando, em seguida, respectivamente, as chaves E_C, M_C, E_S e M_S

      5. O cliente envia o HMAC de todas as mensagens de apresentação

      6. O servidor envia o HMAC de todas as mensagens de apresentação

Protegendo Conexões TCP: TLS

- TLS – Uma visão mais completa
  - Apresentação (handshake) TLS



Protegendo Conexões TCP: TLS

- TLS – Uma visão mais completa
  - Apresentação (handshake) TLS
    - Os dois últimos passos protegem o handshake de adulterações
      - No passo 1 o cliente oferece uma lista de algoritmos
        - Alguns fortes e outros fracos
      - Essa lista é transmitida em texto aberto
      - Trudy pode interceptar essa lista e retirar os algoritmos mais fortes
      - No passo 5 o cliente envia, para o servidor, o HMAC da concatenação de todas as mensagens de handshake envidas e recebidas
      - No passo 6 o servidor envia, para o cliente, o HMAC da concatenação de todas as mensagens de handshake envidas e recebidas
      - Qualquer inconsistência no cliente ou no servidor, a conexão será suspensa.

Protegendo Conexões TCP: TLS

- TLS – Uma visão mais completa
  - Apresentação (handshake) TLS
    - Foi dito, na versão quase-TLS, que o ataque de repetição, inversão ou remoção de segmento foi resolvido com a inclusão de números de sequência atualizados via contador
      - Sendo que esses números fazem parte do HMAC
    - Mas essa solução não previne o ataque de repetição de conexão

Protegendo Conexões TCP: TLS

- TLS – Uma visão mais completa
  - Apresentação (handshake) TLS
    - Exemplo de ataque de repetição de conexão
      - Trudy fareja todas as mensagens entre Bob (cliente) e Alice (servidor)
      - Em outro dia Trudy, se fazendo passar por Bob, envia para Alice as mesmas mensagens enviadas por Bob no dia anterior
      - Alice irá responder para “Bob” com a mesma sequência de mensagens do dia anterior
      - Se Alice for um servidor de comércio eletrônico, ela pensará que Bob está fazendo uma compra igual à feita no dia anterior

Protegendo Conexões TCP: TLS

- TLS – Uma visão mais completa
  - Apresentação (handshake) TLS
    - Exemplo de ataque de repetição de conexão
      - Solução
        - Inclusão do número aleatório (nonce)
        - Assim Alice enviará diferentes nonces a cada sessão TCP
          - Fazendo com que chaves de criptografia sejam diferentes a cada dia ou sessão
        - Dessa forma nouces previnem essa forma de ataque
  - Os processos de derivação de chave e transferência de dados permanecem os mesmos do quase-TLS

Protegendo Conexões TCP: TLS

- Encerramento de conexão
  - Tanto Alice quanto Bob podem querer encerrar uma conexão
    - Uma conexão TLS pode ser encerrada enviando um segmento TCP FIN
    - Mas essa forma de encerramento pode permitir um ataque de truncamento
      - Trudy, se passando por Bob, pode enviar o segmento TCP FIN e encerrar prematuramente a sessão

Protegendo Conexões TCP: TLS

- Encerramento de conexão
  - Tanto Alice quanto Bob podem querer encerrar uma conexão
    - Solução para o ataque de truncamento
      - Alice só deve aceitar um segmento TCP FIN após ter recebido de Bob um registro TLS de encerramento